Analyse NIS2 / DORA

> ***Statut : cible.*** *Ce document décrit ce que l'équipe vise et a décidé, pas ce qui est déjà codé. L'état réel du code est suivi dans* `constat/etat-implementation.md`*.*

> *Ticket : WOR-69 · Responsable : Cédric · Version 0.1 du 19/10/2026*
>
> *Ce document s'appuie sur la matrice de risques (*`ebios-rm.md`*) et sur le coût d'un arrêt (*`services-critiques.md`*). Il alimente le PCA/PRA (WOR-71) et les recommandations à la direction (WOR-72).*
>
> *Le sujet demande de* ***distinguer les exigences pertinentes des obligations qui ne peuvent pas être démontrées par un prototype de quatre jours****. C'est la structure de ce document : pour chaque exigence, ce que le démonstrateur prouve, et ce qu'il ne prouve pas.*

1. Quel texte s'applique ?

Question	Réponse	Fondement
Notre entreprise fictive est-elle dans le champ de DORA ?	**Oui.** Un opérateur de paiement est un établissement de paiement, explicitement visé.	DORA (règlement UE 2022/2554), art. 2.1 b. Applicable depuis le 17/01/2025.
Est-elle dans le champ de NIS2 ?	**Non.** Les établissements de paiement ne figurent pas à l'annexe I de NIS2, dont le secteur bancaire ne vise que les établissements de crédit.	NIS2 (directive UE 2022/2555), annexe I.
Si les deux s'appliquaient, lequel prime ?	**DORA.** C'est un acte sectoriel qui prévoit des mesures au moins équivalentes ; il remplace NIS2 pour la gestion du risque et la notification des incidents.	NIS2, art. 4 et considérant 28.
Qui est l'autorité compétente ?	L'**ACPR** pour un établissement de paiement en France.	Désignation nationale au titre de DORA.
Le cadre simplifié (art. 16) s'applique-t-il ?	**Non.** Avec 158 M€ de revenu annuel et 200 partenaires, l'entreprise n'est pas une petite structure exemptée.	DORA, art. 16.

Conclusion : on raisonne en DORA. NIS2 reste utile comme grille de lecture (mesures de l'art. 21, chaîne d'approvisionnement), mais ce n'est pas le texte qui nous oblige.

2. Ce que DORA exige, et ce que le démonstrateur prouve

Légende : ✅ démontré par le prototype · 🟡 démontré en partie · ❌ non démontrable en 4 jours (à traiter dans un contexte industriel).

Les biens supports (BS) sont ceux de `ebios-rm.md`. Les preuves sont **prévues** : elles seront confirmées par les résultats d'essais du mercredi et du jeudi (WOR-73). L'état réel du code au 20/10 est suivi dans `constat/etat-implementation.md`.

2.1 Gestion du risque TIC (art. 5 à 16)

Exigence	Article	Ce que le prototype montre	Composants	Preuve attendue	Statut
Cadre de gestion du risque TIC documenté	6	Analyse EBIOS RM, services critiques chiffrés	—	`ebios-rm.md`, `services-critiques.md`	✅
Identifier les fonctions critiques et leurs dépendances	8	Services classés par priorité, biens supports reliés aux valeurs métier	Tous	Tableaux VM ↔ BS	✅
Protection et prévention : moindre privilège, chiffrement, gestion des secrets	9	Filtrage WAF, secrets hors du code, privilèges limités des conteneurs	BS5, BS9, BS8	Configuration WAF, HashiCorp Vault, revue des droits du moteur de remédiation (WOR-64)	🟡 un seul hôte ; au 20/10, API derrière le WAF, mais secrets de l'application hors de Vault et port de la base publié
Détection rapide des activités anormales	10	Détection ML sur les métriques et journaux, alertes SIEM	BS6, BS7	Horodatage attaque → alerte, mesuré pendant l'essai	🟡 au 20/10, modèle et alertes en place, délai de détection pas encore mesuré
Réponse et rétablissement : politique de continuité, reprise des fonctions critiques	11	**Cœur de la démo** : remédiation automatique, puis transaction fictive réussie	BS8, BS2, BS4	Durée attaque → transaction réussie, comparée au RTO (WOR-70)	🟡 au 20/10, moteur et vérification par transaction en place, RTO pas encore mesuré
Tests du plan de continuité	11.6	Scénario d'attaque rejoué et chronométré	Tous	Résultats d'essais	🟡 un seul scénario, pas de programme annuel
Sauvegarde et restauration, sans perte de données validées	12	Restauration de la base, contrôle de cohérence après reprise	BS4	Comptage des transactions avant / après	❌ au 20/10, aucune sauvegarde ; la restauration repart des données de départ
Capacités redondantes	12.4	—	BS11	—	❌ hôte unique, point de défaillance unique assumé
Retour d'expérience après incident	13	Analyse post-incident à partir des journaux, aidée par l'assistant RAG	BS6, BS10	Rapport d'incident généré après l'essai	🟡
Communication de crise	14	—	—	Plan de communication dans le PCA (WOR-71)	🟡 sur papier
Responsabilité de l'organe de direction, formation	5	—	—	—	❌ pas d'organe de direction réel

2.2 Gestion et notification des incidents (art. 17 à 23)

Exigence	Article	Ce que le prototype montre	Statut
Processus de détection, journalisation et suivi des incidents	17	Chaque incident détecté est horodaté et conservé dans le SIEM	🟡 au 20/10, blocages du WAF et accès à Vault journalisés et visibles dans le tableau SOC/SIEM ; pas encore de règle d'alerte ni de suivi d'incident
Classification selon les critères réglementaires	18	Grille appliquée au scénario de la démo (voir section 3)	✅ sur papier, à partir des mesures réelles
Notification des incidents majeurs à l'ACPR : initiale, intermédiaire, finale	19	Les journaux du SIEM contiennent les informations nécessaires. Aucune notification réelle n'est envoyée.	🟡
Information des clients touchés	19.3	—	❌

2.3 Tests de résilience (art. 24 à 27)

Exigence	Article	Ce que le prototype montre	Statut
Programme de tests : analyses de vulnérabilités, tests de scénarios, tests de performance	24, 25	Scénario Red Team depuis le PC Attaquant, scans de vulnérabilités	🟡 un essai ponctuel, pas un programme
Tests de pénétration fondés sur la menace (TLPT), tous les 3 ans, par des testeurs indépendants	26, 27	—	❌ réservé aux entités désignées, exige des testeurs externes

2.4 Risque lié aux prestataires TIC (art. 28 à 44)

Exigence	Article	Ce que le prototype montre	Statut
Registre des accords avec les prestataires TIC	28.3	Inventaire des briques utilisées (images Docker, Ollama, modèles)	🟡 inventaire technique, pas contractuel
Clauses contractuelles obligatoires, stratégies de sortie	28.8, 30	—	❌ aucun contrat
Concentration du risque sur un prestataire	29	Tout est auto-hébergé, sauf l'assistant de discussion de l'application, qui appelle OpenAI	🟡 un prestataire externe à inscrire au registre, ou à remplacer par le modèle local (Ollama)

2.5 Partage d'informations (art. 45)

Facultatif. Non traité.

3. Le scénario de la démo est-il un incident majeur ?

DORA classe un incident comme **majeur** s'il touche un service critique et, en plus, soit entraîne une perte de données après un accès malveillant, soit dépasse les seuils d'au moins deux autres critères (règlement délégué (UE) 2024/1772). Les critères utiles ici :

- **Durée** : interruption d'un service critique de plus de 2 h (ou incident de plus de 24 h) ;
- **Clients touchés** : plus de 10 % des clients ou des contreparties financières ;
- **Impact économique** : plus de 100 k€ de coûts et pertes ;
- **Perte de données** : atteinte à la disponibilité, l'intégrité ou la confidentialité des données.

Appliqué au risque R1 (déni de service sur l'API, scénario principal pressenti), en heure de pointe et avec les 200 partenaires touchés :

Mode de reprise	Durée	Critères dépassés	Majeur ?	Conséquence
Automatique (cible de la démo)	≤ 5 min	Clients touchés	**Non**	Incident enregistré et classé, pas de notification
Manuelle	30 min à 2 h	Clients touchés, impact économique (pénalité SLA ~650 k€)	**Oui, probablement**	Notification initiale à l'ACPR, puis rapports intermédiaire et final
Manuelle, longue	> 2 h	Clients, durée, impact économique	**Oui**	Idem, et incident G4 dans EBIOS

> ***Attention :*** *le critère économique peut faire basculer l'incident en majeur* ***avant*** *le seuil de 2 h, dès que la pénalité SLA est déclenchée (43 min d'arrêt cumulé dans le mois).*
>
> ***Incidents récurrents :*** *des incidents qui ne sont pas majeurs un par un, mais qui ont la même cause apparente, se sont produits au moins deux fois en 6 mois et dépassent ensemble les seuils, sont traités comme un seul incident majeur (règlement délégué (UE) 2024/1772, art. 16). Des dénis de service courts et répétés peuvent donc finir par imposer une notification.*

Pour R2 et R5 (injection, exfiltration), le critère « perte de données après accès malveillant » suffit, avec la criticité du service, à rendre l'incident majeur, **quelle que soit la vitesse de reprise**. Restaurer la disponibilité ne dispense pas de notifier. C'est la distinction que le sujet demande de ne pas manquer (voir WOR-39).

Argument pour la direction : la reprise automatique en moins de 5 minutes n'est pas seulement un gain technique. Elle maintient un déni de service sous les seuils de DORA, ce qui évite la notification réglementaire et la pénalité contractuelle.

4. Ce que nous ne pouvons pas démontrer, et ce qu'il faudrait en contexte industriel

Limite du prototype	Exigence concernée	Ce qu'il faudrait faire
Un seul PC Hôte	Redondance (art. 12)	Deuxième site ou deuxième zone de disponibilité, bascule testée
Sauvegardes sur le même hôte	Sauvegarde isolée (art. 12)	Copie hors site, immuable, restauration testée chaque trimestre
Un seul scénario d'attaque	Programme de tests (art. 24)	Programme annuel couvrant tous les risques retenus dans EBIOS
Pas de testeurs indépendants	TLPT (art. 26)	Campagne TLPT (cadre TIBER-EU) si l'entité est désignée
Pas de contrats	Prestataires TIC (art. 28 à 30)	Registre d'information, clauses DORA, plans de sortie
Pas d'organe de direction	Gouvernance (art. 5)	Validation du cadre de risque par la direction, formation annuelle
Pas de notification réelle	Notification (art. 19)	Procédure de notification à l'ACPR, astreinte, modèles de rapports
Données fictives	RGPD	Analyse d'impact (AIPD) sur les données réelles

5. Pistes pour les recommandations (WOR-72)

1. **Garder la reprise automatique comme priorité** : c'est elle qui maintient les incidents de disponibilité sous les seuils de DORA (section 3).
2. **Traiter à part les incidents d'intégrité et de confidentialité** : la remédiation automatique ne doit pas effacer les traces. Les journaux doivent être conservés avant toute restauration, car ils serviront à la notification.
3. **Préparer automatiquement le brouillon de notification** : le SIEM et l'assistant RAG disposent déjà des horodatages et des impacts. Un humain valide et envoie.
4. **Budgéter en priorité la redondance et les sauvegardes hors site** : ce sont les deux écarts les plus lourds face à l'art. 12.
5. **Encadrer le moteur de remédiation** (R3, WOR-64) : un dispositif de défense aux droits élevés est lui-même un bien critique au sens de l'art. 9.

À valider avec les coachs

1. La qualification « établissement de paiement, donc DORA, NIS2 en second plan » est-elle la lecture attendue ?
2. Le niveau de détail : faut-il citer les articles, ou rester au niveau des cinq piliers de DORA pour le dossier final ?